BÁO CÁO DEMO BRUTE FORCE VÀ KIỂM CHỨNG CAPTCHA TRÊN SHOPLAB

Phân tích thử nghiệm đăng nhập bằng Burp Suite Intruder

Ngày thực nghiệm 01 tháng 10 năm 2026 | Môi trường lab cục bộ

Kết luận chính

Intruder đã gửi được các cặp email và mật khẩu đến API đăng nhập. Ảnh trong tài liệu gốc ghi nhận một yêu cầu sử dụng admin@shoplab.local được trả HTTP 200, có accessToken và user.role là ADMIN. Đây là bằng chứng xác thực thành công bằng thông tin đăng nhập hợp lệ trong lab.

Tuy nhiên, chưa có bằng chứng cho thấy đã vượt CAPTCHA hoặc vô hiệu hóa giới hạn theo IP. Các ảnh khác ghi nhận HTTP 429 khi hết hạn mức 30 yêu cầu trong 15 phút. Kiểm thử đối chứng cũng cho thấy đăng nhập đúng tài khoản test không xóa bộ đếm sai của một email khác.

Mục tiêu và phạm vi

Báo cáo mô tả việc chuẩn bị dữ liệu, bắt request, cấu hình Pitchfork, xử lý lỗi mã hóa, đọc phản hồi và kiểm chứng hai lớp bảo vệ. Đối tượng thử nghiệm là ShopLab tại http://127.0.0.1:5173, endpoint POST /api/auth/login. Phạm vi chỉ gồm ứng dụng lab do người thực hiện quản lý.

Thành phần	Thông tin
Ứng dụng	ShopLab với frontend React và backend Express
Công cụ trong ảnh	Burp Suite Professional v2026.3.3
Dữ liệu thử	accounts.txt và passwords.txt trên Desktop; 300 dòng mỗi file tại lần kiểm tra
Tài khoản đối chứng	test@shoplab.local; mật khẩu hoa123456789
Nguồn bằng chứng	10 ảnh trong bruteforce.docx, ảnh bổ sung trong hội thoại, mã nguồn và results.json

Thông tin đăng nhập trong báo cáo là dữ liệu demo của lab. Các ảnh được phân tích theo từng lượt chạy; không cộng gộp các bảng kết quả khác thời điểm thành một chuỗi thử nghiệm duy nhất.

1 Cơ chế xử lý đăng nhập

Có hai bộ đếm độc lập. Bộ giới hạn lưu số yêu cầu theo địa chỉ IP mà backend nhìn thấy. Bộ đếm CAPTCHA lưu số lần xác thực thất bại theo email đã được chuẩn hóa. Vì vậy, thay email không tạo hạn mức IP mới, còn đăng nhập đúng một email không xóa số lần sai của email khác.

Lớp kiểm tra	Điều kiện	Phản hồi
Giới hạn yêu cầu	Quá 30 yêu cầu trong cửa sổ 15 phút theo IP	429 RATE_LIMIT
Kiểm tra dữ liệu	Email không hợp lệ hoặc dữ liệu sai schema	400 VALIDATION_ERROR
CAPTCHA	Email đã sai ít nhất 3 lần và thiếu hoặc sai CAPTCHA	401 CAPTCHA_REQUIRED
Thông tin đăng nhập	Email không tồn tại, tài khoản không hoạt động hoặc mật khẩu sai	401 LOGIN_FAILED
Tạo phiên	Thông tin hợp lệ và đáp ứng CAPTCHA nếu đang bắt buộc	200, accessToken và thông tin user

Thứ tự xử lý trong mã nguồn

```
POST /api/auth/login
  -> limiter theo IP
  -> schema email va password
  -> loginAttempt theo email
  -> kiem tra CAPTCHA neu can
  -> kiem tra mat khau
  -> tao session va tra token
```

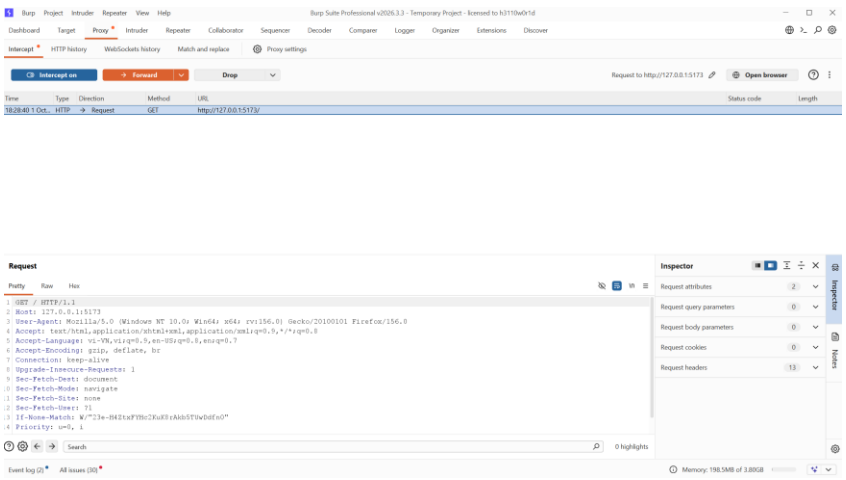
Trong auth.routes.js, limiter được gắn trước phần kiểm tra schema và loginAttempt. Vì vậy, khi đã hết hạn mức IP, cả email đúng lẫn email sai đều nhận 429 trước khi backend kiểm tra mật khẩu. Request sai định dạng email vẫn tiêu thụ hạn mức nếu đã đi vào route này.

Limiter hiện dùng chung cho register, login, login-captcha, forgot-password và reset-password. Không có cấu hình bỏ qua request thành công. Refresh và logout không gắn limiter này. Qua reverse proxy, khóa IP phụ thuộc địa chỉ backend thực sự nhận được; chưa kiểm thử việc phân biệt nhiều máy khách ngoài lab.

Vòng đời CAPTCHA

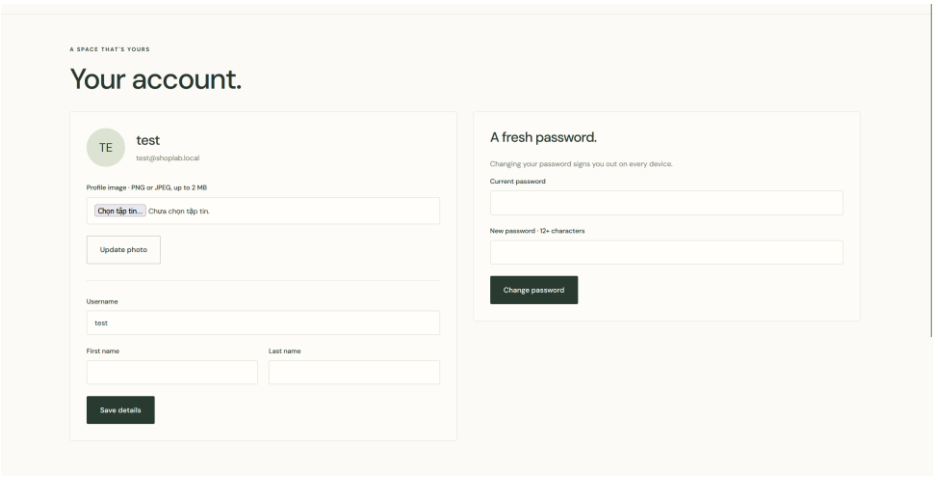
Sau lần sai thứ 3, response vẫn là LOGIN_FAILED nhưng kèm ảnh CAPTCHA. Từ lần tiếp theo, backend yêu cầu captchaId và captchaAnswer. Mã ảnh gồm 6 ký tự, không phân biệt hoa thường, hết hạn sau 2 phút và được thay mới sau một lần thử thất bại hoặc đổi mã. Trạng thái sai hết hạn sau 15 phút không phát sinh thêm lần kiểm tra mật khẩu thất bại; đăng nhập thành công xóa trạng thái của chính email đó.

2 Chuẩn bị ứng dụng và tài khoản đối chứng



Hình 1 Burp Proxy đang bắt request tới ShopLab cục bộ

Hình 1 cho thấy Proxy Intercept đang bật và bắt một request GET tới trang gốc. Đây là bước kiểm tra trình duyệt đã đi qua Burp; request GET này chưa phải yêu cầu đăng nhập. Cần Forward để trang tiếp tục tải rồi thực hiện đăng nhập để thu được POST /api/auth/login.

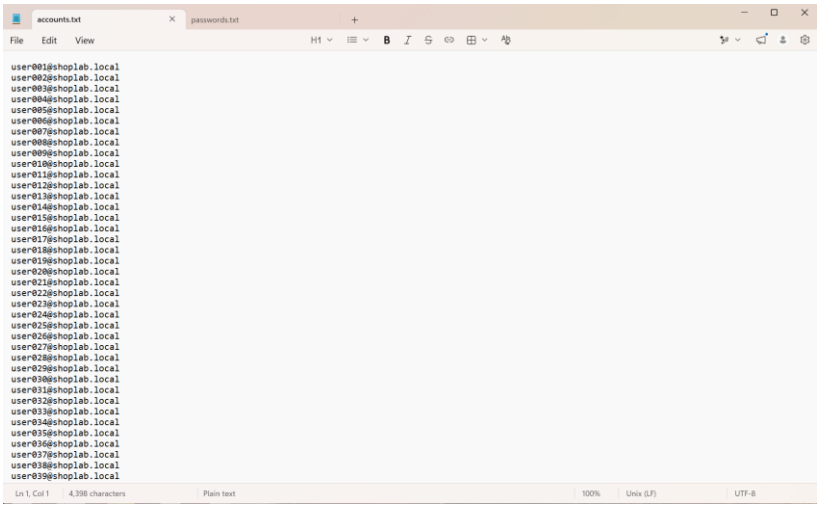


Hình 2 Trang tài khoản của người dùng test sau khi đăng nhập

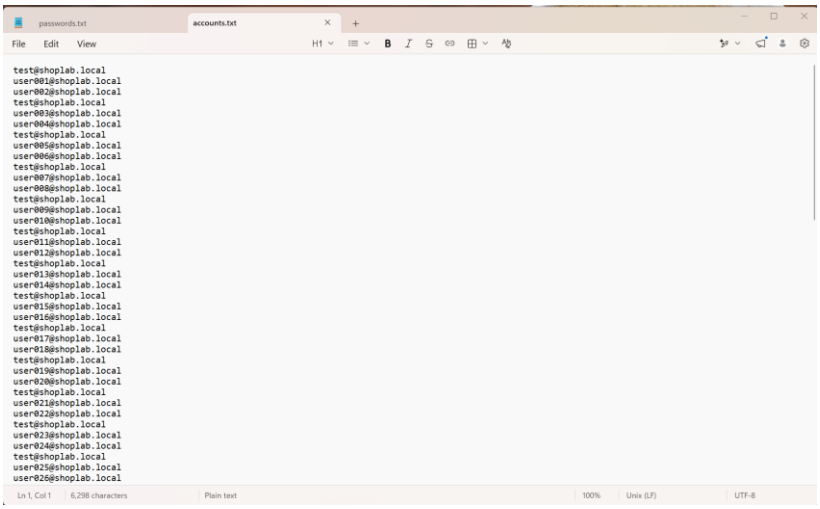
Tài khoản test được dùng làm đối chứng với cặp thông tin đã biết đúng. Trang hồ sơ trong Hình 2 cho thấy phiên đăng nhập của test hoạt động. Riêng giao diện hồ sơ không đủ xác minh role; khi cần khẳng định quyền, phải đọc user.role trong response hoặc kiểm tra một chức năng yêu cầu quyền tương ứng.

Tài khoản admin và mật khẩu Password123! được nêu sẵn trong tài liệu gốc. Vì vậy, khi cặp này xuất hiện trong danh sách thử, cần mô tả là nhận diện một cặp hợp lệ trong tập dữ liệu lab, không kết luận đã tìm ra một mật khẩu chưa từng biết.

3 Chuẩn bị danh sách email



Hình 3 Danh sách email trước khi chèn tài khoản đối chứng

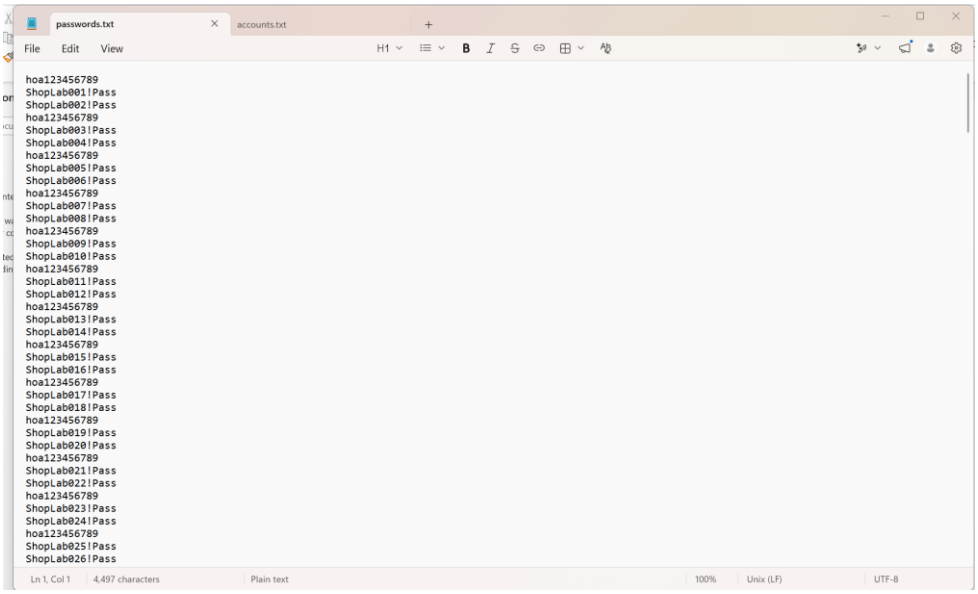


Hình 4 Danh sách email sau khi chèn test xen kẽ

Hai ảnh cho thấy danh sách ban đầu gồm các địa chỉ user001, user002 và các email tiếp theo. Danh sách sau đó chèn test@shoplab.local giữa các nhóm email. Việc chèn phải thực hiện tương ứng ở file mật khẩu để không làm lệch cặp khi dùng Pitchfork.

Giả thuyết demo là một lần đăng nhập đúng có thể đặt lại bộ đếm chống đoán mật khẩu. Giả thuyết này cần kiểm chứng, không được mặc định là đã vượt bảo vệ. Với mã nguồn hiện tại, bộ đếm CAPTCHA gắn với email; khi mỗi email mục tiêu chỉ bị thử một lần, việc chưa thấy CAPTCHA là hành vi đúng theo ngưỡng 3 lần, dù có chèn tài khoản test hay không.

4 Ghép danh sách mật khẩu theo dòng



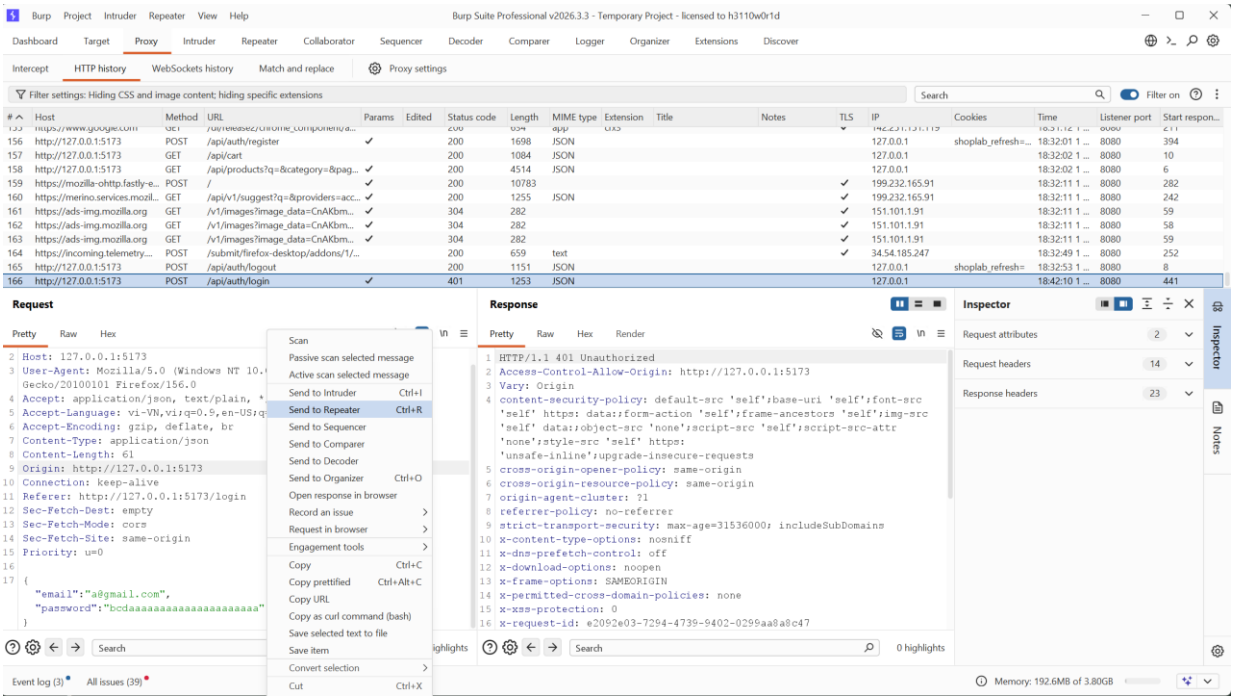
Hình 5 File passwords.txt với mật khẩu đối chứng xen kẽ

Tên file thực tế được kiểm tra là passwords.txt. Mỗi dòng mật khẩu phải tương ứng với email ở cùng số dòng trong accounts.txt. Không sắp xếp hoặc loại trùng riêng lẻ một file sau khi đã ghép cặp.

Dòng	Email	Mật khẩu trong dữ liệu lab
1	test@shoplab.local	hoa123456789
2	user001@shoplab.local	ShopLab001!Pass
3	user002@shoplab.local	ShopLab002!Pass
4	test@shoplab.local	hoa123456789
5	user003@shoplab.local	ShopLab003!Pass
6	user004@shoplab.local	ShopLab004!Pass

Trong Pitchfork, dòng thứ n của hai file tạo thành một request; công cụ không thử mọi tổ hợp email và mật khẩu. Danh sách 300 dòng là một tập cặp thông tin đăng nhập. Kịch bản này thuộc nhóm thử đăng nhập tự động bằng danh sách; không đủ để khẳng định đã dò toàn bộ không gian mật khẩu.

5 Bắt và kiểm tra request đăng nhập



Hình 6 Chọn POST đăng nhập trong HTTP history và chuyển sang công cụ kiểm thử

Trong Proxy HTTP history, chọn đúng POST /api/auth/login của ShopLab. Ảnh thể hiện một request nhận 401 và menu chuyển request; mục đang được tô sáng là Send to Repeater. Có thể dùng Repeater để xác nhận request hoạt động trước, sau đó chuyển sang Intruder bằng Send to Intruder.

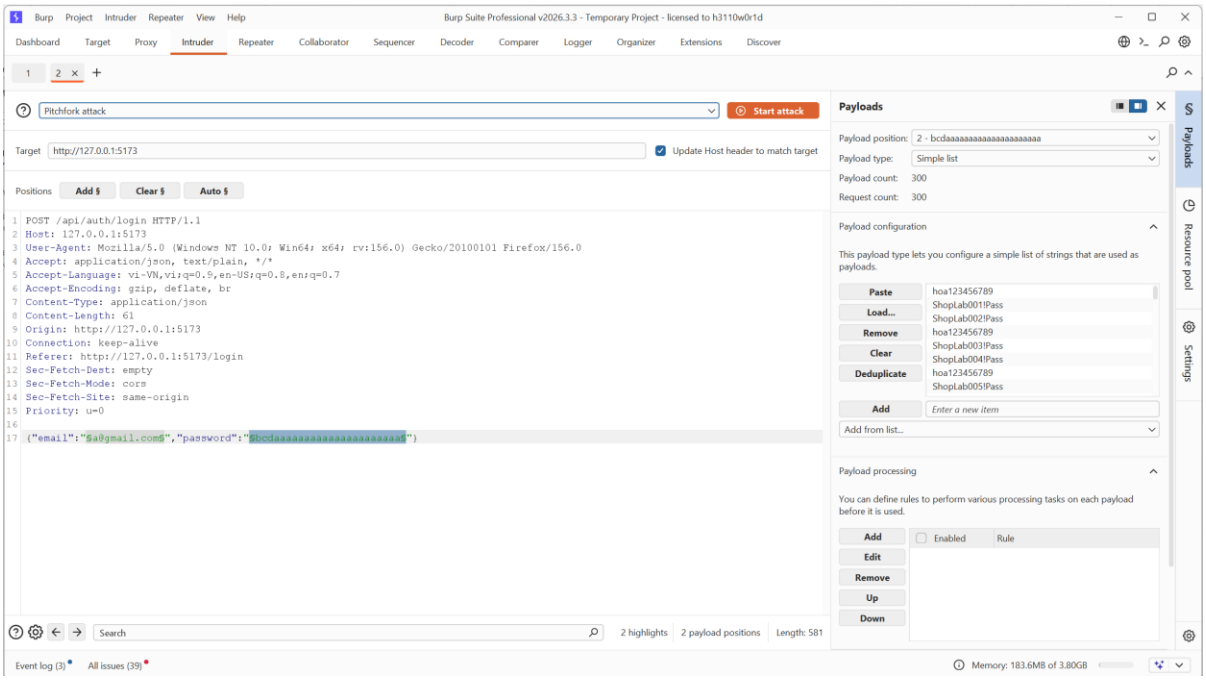
```
POST /api/auth/login HTTP/1.1
Host: 127.0.0.1:5173
Content-Type: application/json
Origin: http://127.0.0.1:5173

{"email":"test@shoplab.local","password":"hoa123456789"}
```

Đây là mẫu rút gọn để giải thích cấu trúc. Khi gửi thật, Burp cần tự tính Content-Length. Phải có dòng trống giữa phần header và JSON. Không sao chép nguyên một giá trị Content-Length cũ sang body có độ dài khác.

Nếu Repeater trả 200 cho tài khoản đối chứng, đường dẫn API và cặp thông tin đang hợp lệ ở thời điểm đó. Điều này chưa bảo đảm mọi request Intruder sẽ trả 200: payload có thể sai, bị mã hóa, lệch dòng, hoặc hạn mức IP có thể đã cạn trước khi Intruder gửi.

6 Cấu hình Pitchfork trong Intruder



Hình 7 Hai vị trí payload trong JSON và danh sách mật khẩu của Pitchfork

Chọn Pitchfork attack. Dùng Clear § để xóa vị trí tự động nếu có, sau đó chỉ đánh dấu giá trị của email và password. Dấu ngoặc kép JSON nằm ngoài vùng thay thế. Thiết lập mục tiêu là http://127.0.0.1:5173.

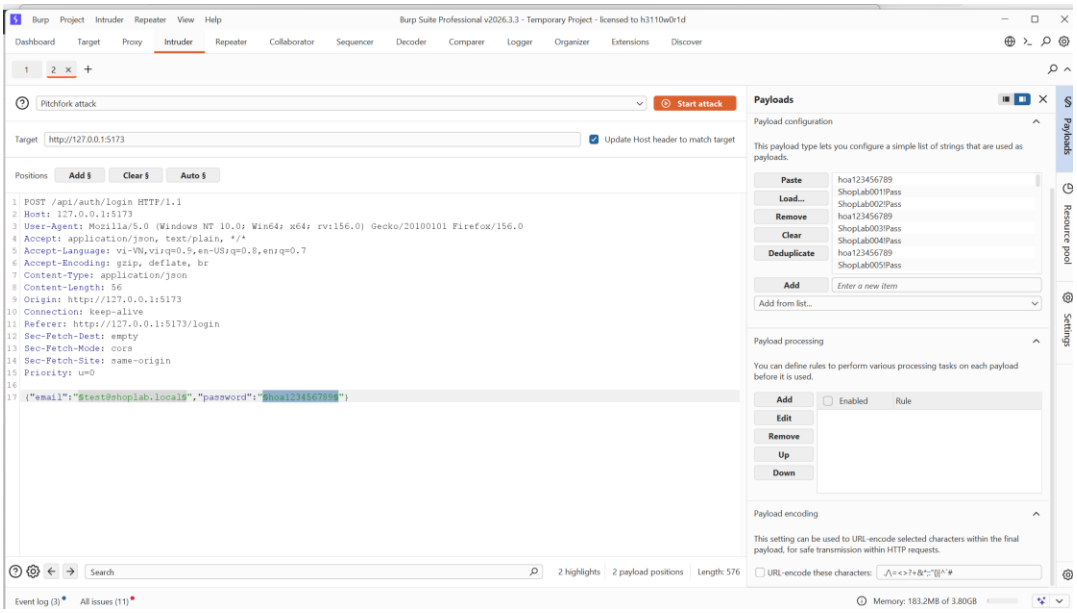
```
{"email":"§test@shoplab.local§","password":"§hoa123456789§"}
```

Payload position 1 dùng Simple list và nạp accounts.txt. Payload position 2 nạp passwords.txt. Kiểm tra tổng số dòng bằng nhau và kiểm tra một vài cặp đầu trước khi chạy. Ảnh đang hiển thị danh sách password nên không thể suy ra cấu hình encoding của email từ panel này.

Trong từng payload position, kiểm tra Payload processing không có quy tắc URL-encode, rồi tắt URL-encode these characters tại Payload encoding. Với body JSON, dấu chấm trong email phải được giữ nguyên. Bật Update Content-Length header trong Settings.

Để quan sát thứ tự rõ ràng, dùng Resource pool riêng với Maximum concurrent requests bằng 1. Có thể tắt Make unmodified baseline request để kết quả chỉ gồm các dòng dữ liệu; nếu bật, dòng 0 là request gốc và cũng tiêu thụ hạn mức đăng nhập. Chạy bộ 6 dòng trước khi dùng tập lớn. Các thiết lập này được mô tả trong tài liệu PortSwigger [R1–R4].

7 Giải thích các lỗi trong quá trình demo



Hình 8 URL encoding đã tắt ở panel đang hiển thị danh sách mật khẩu

Email bị đổi thành chuỗi phần trăm

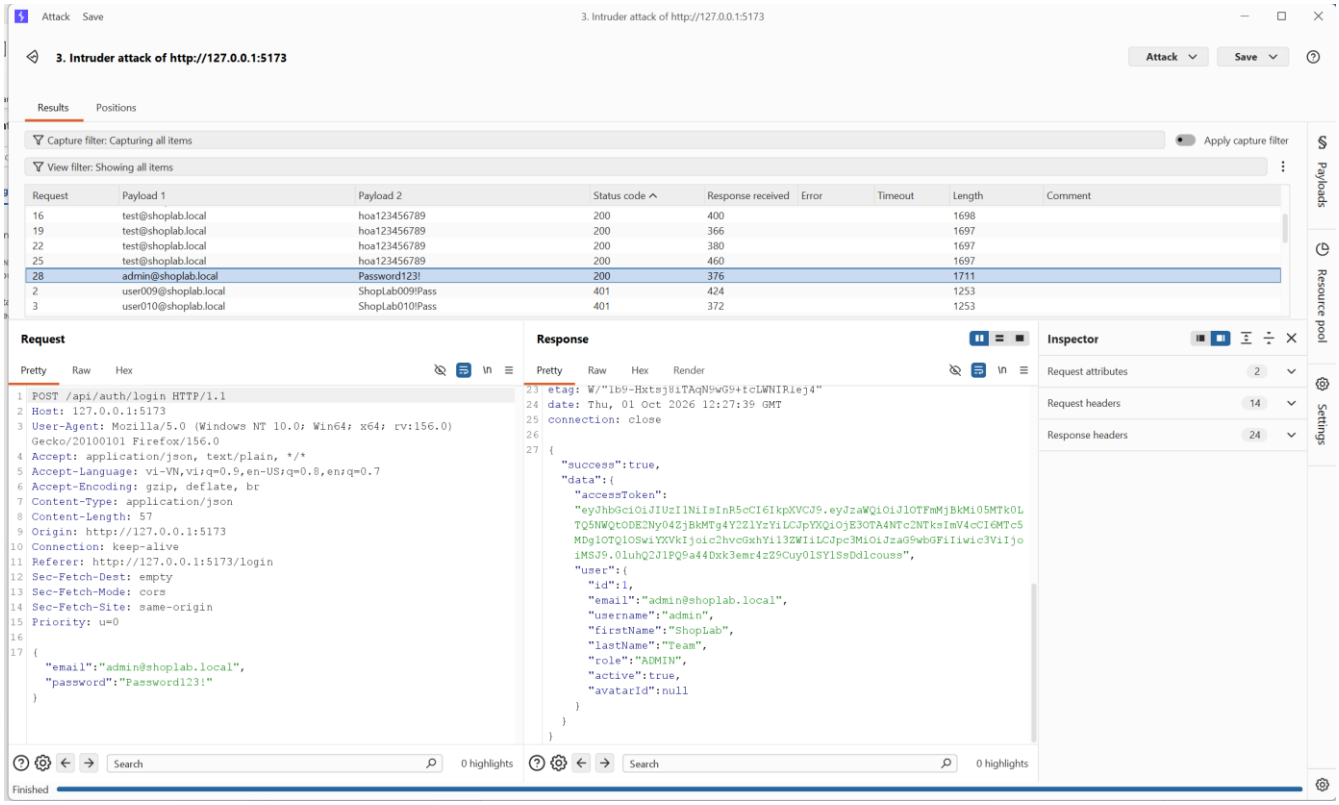
Các ảnh trao đổi trước đó ghi nhận test@shoplab%2elocal. %2e là dạng URL-encoded của dấu chấm. Backend nhận JSON không tự URL-decode giá trị email, nên schema báo email: Invalid email address. Đây là lỗi đầu vào, không phải CAPTCHA. Cột Payload có thể hiển thị chuỗi gốc, trong khi tab Request cho thấy chuỗi sau xử lý.

Hình 8 chỉ xác nhận URL encoding của danh sách đang chọn đã tắt. Cần chọn lại payload email ở đầu panel và tắt ở vị trí đó, rồi tạo lượt chạy mới. Các request đã gửi trong kết quả cũ không bị thay đổi bởi việc chỉnh cấu hình.

Phân biệt các hiện tượng khác

Hiện tượng	Diễn giải
400 và JSON VALIDATION_ERROR	Request đã tới phần kiểm tra schema; đọc error.message để biết trường sai.
400 chỉ có dòng trạng thái	Chưa đủ dữ liệu xác định lỗi. Kiểm tra request Raw, framing HTTP và Content-Length; không khẳng định CAPTCHA gây ra.
Dòng 0 ghi baseline request	Request gốc dùng để so sánh, không phải tên lỗi.
Starting và Response trống	Chưa có phản hồi hiển thị. Cần kiểm tra lượt chạy, pool và request bằng Repeater; chưa xác định nguyên nhân từ ảnh.
429 Too Many Requests	Giới hạn số yêu cầu đã kích hoạt, độc lập với URL encoding.

8 Phân tích ảnh đăng nhập tài khoản admin



Hình 9 Lượt chạy trong tài liệu gốc có response 200 và user.role ADMIN

Ở dòng request 28 của Hình 9, email là admin@shoplab.local và mật khẩu là Password123!. Phản hồi hiển thị success: true, accessToken, user.email là admin@shoplab.local và role là ADMIN. Các trường này xác nhận API đã tạo phiên cho tài khoản quản trị tại thời điểm của ảnh.

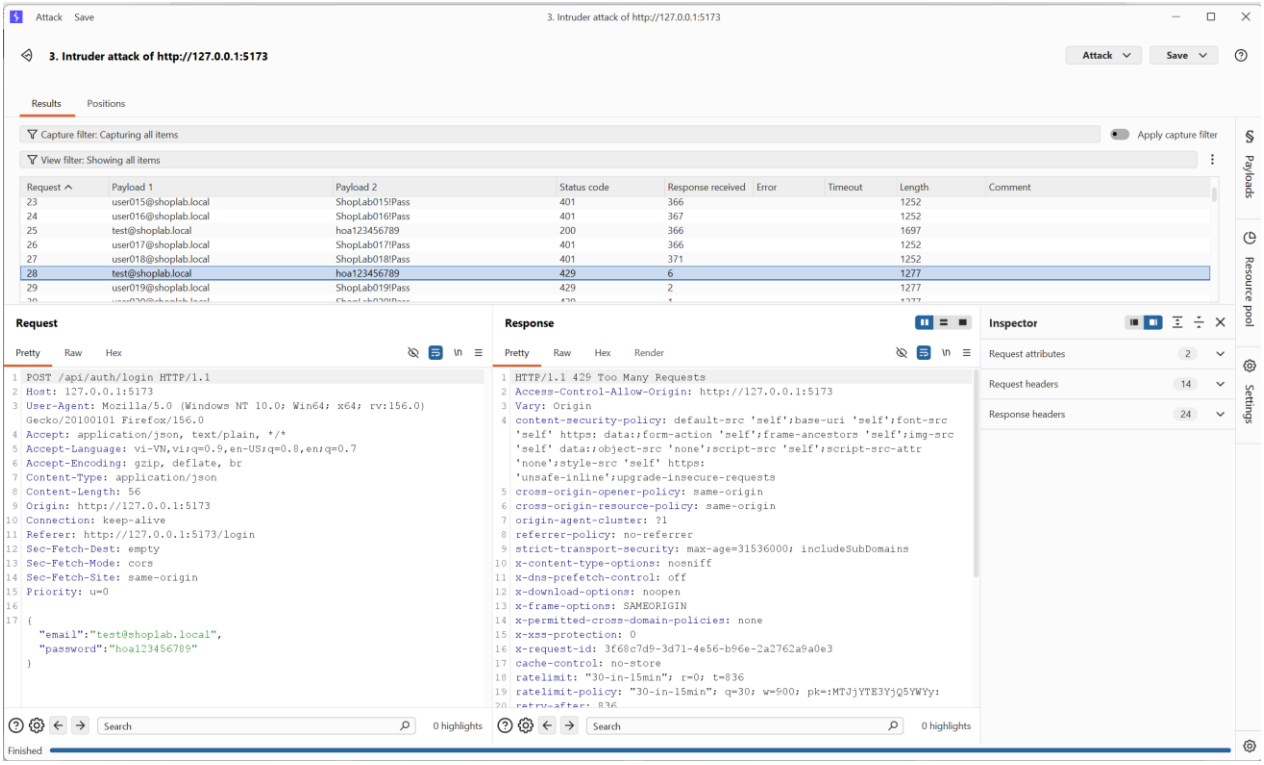
```
HTTP 200
success: true
user.email: admin@shoplab.local
user.role: ADMIN
accessToken: co trong response
```

Bằng chứng này không cho thấy tài khoản admin đã bị thử sai 3 lần trước request đó, không cho thấy một CAPTCHA đang bắt buộc được bỏ qua và cũng không cho thấy hạn mức IP đã cạn ngay trước khi request thành công. Vì vậy, không đủ cơ sở kết luận “thoát rate limit IP và CAPTCHA”.

Cặp admin đã được nêu trong phần chuẩn bị của tài liệu. Kết quả phù hợp với việc gửi đúng thông tin khi điều kiện đăng nhập còn cho phép. Ảnh cũng chưa kiểm chứng token được dùng để thực hiện thao tác quản trị; role trong response là bằng chứng xác thực, không thay thế bài kiểm thử phân quyền riêng.

Các dòng 200 của test là những lần đăng nhập hợp lệ của chính test. Chúng không phải bằng chứng đã đăng nhập được các email user001, user002 hoặc đã xóa bộ đếm của admin.

9 Vì sao từ dòng 28 xuất hiện HTTP 429



Hình 10 Lượt chạy khác bị chặn ở dòng 28 dù gửi tài khoản test hợp lệ

Ảnh bổ sung cho thấy dòng 25 còn trả 200 cho test, các dòng 26 và 27 trả 401, đến dòng 28 trả 429. Email và mật khẩu của test ở dòng 28 đúng định dạng; kết quả này phù hợp với limiter chạy trước phần xác thực.

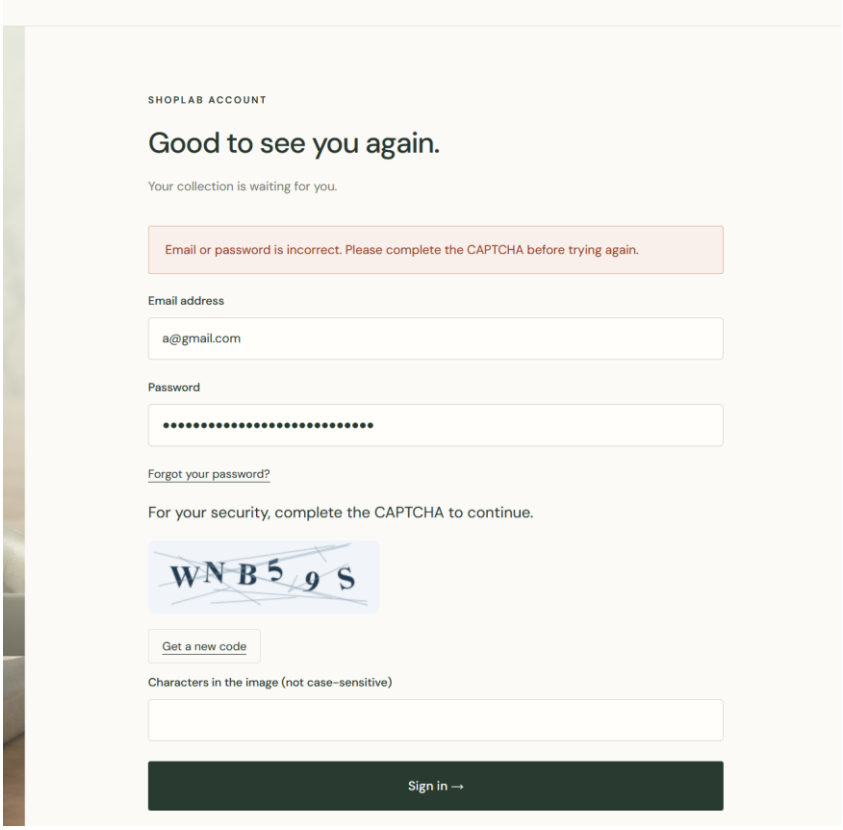
```
HTTP/1.1 429 Too Many Requests
ratelimit: "30-in-15min"; r=0; t=836
retry-after: 836
```

30-in-15min là chính sách 30 yêu cầu trong 15 phút; r=0 nghĩa là không còn lượt; t=836 và Retry-After: 836 thể hiện còn 836 giây, tức 13 phút 56 giây, tại thời điểm response. Thời gian này không phải số giây còn lại tại lúc đọc báo cáo.

Số thứ tự Intruder chỉ thuộc lượt chạy đang xem. Backend còn tính baseline ở dòng 0 và những request trước đó từ Repeater, trình duyệt hoặc các route dùng chung limiter. Vì vậy, việc bị chặn ở dòng 28 không mâu thuẫn với ngưỡng 30. Không có toàn bộ lịch sử request nên chưa thể xác định chính xác các lượt bổ sung nào đã tiêu thụ hạn mức.

Hình 9 và Hình 10 là hai bằng chứng khác nhau: dòng 28 trong một ảnh là admin trả 200, trong ảnh còn lại là test trả 429. Không dùng chỉ số dòng để coi chúng là cùng một request hay suy ra bộ giới hạn hoạt động ngẫu nhiên.

10 Quan sát CAPTCHA trên giao diện



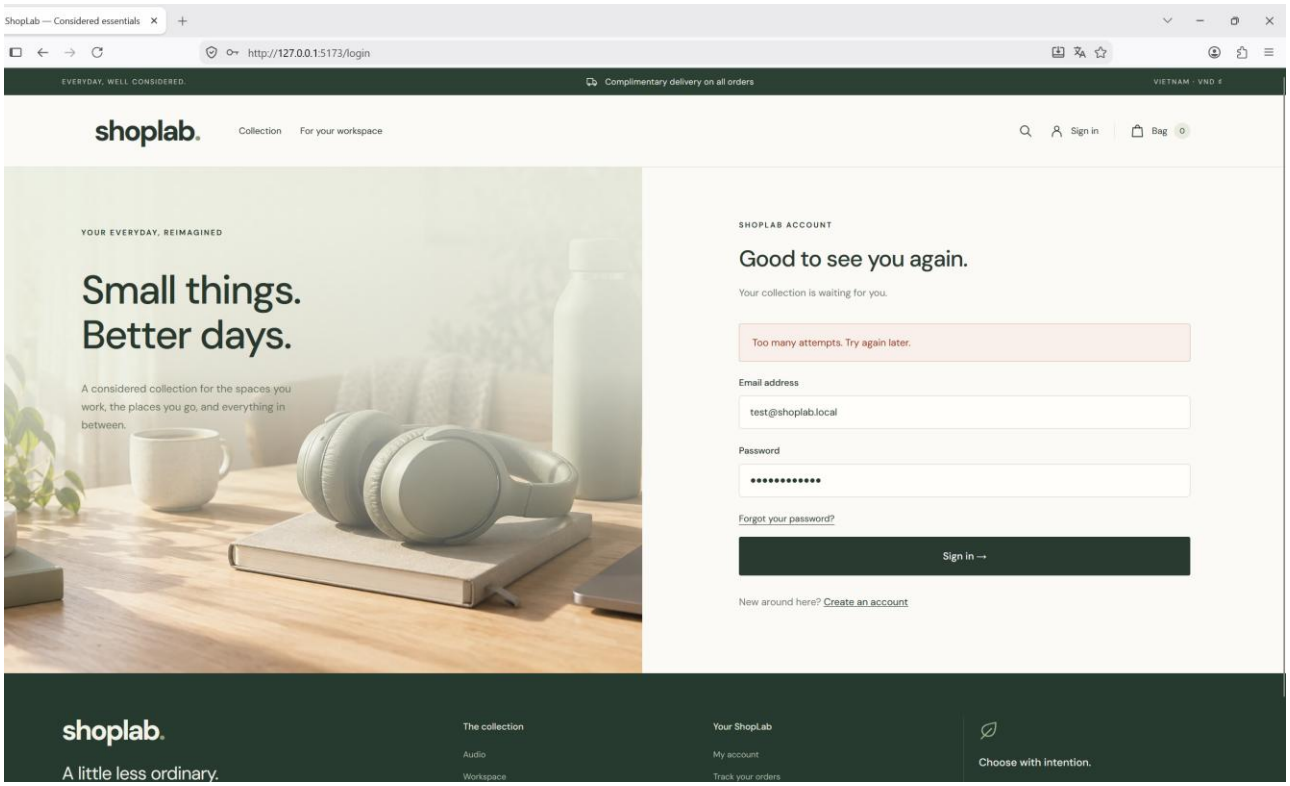
Hình 11 Form đăng nhập hiển thị ảnh CAPTCHA và ô nhập ký tự

Hình 11 thể hiện thông báo yêu cầu hoàn thành CAPTCHA, một ảnh gồm các ký tự, nút Get a new code và ô Characters in the image. Ghi chú thực nghiệm mô tả ảnh này xuất hiện sau 3 lần nhập sai. Ảnh riêng lẻ xác nhận trạng thái CAPTCHA đã hiện, còn ngưỡng chính xác được đối chiếu thêm bằng mã nguồn và kết quả kiểm thử ở phần 12.

Để quan sát ngưỡng, cần giữ nguyên một email qua các lần sai. Nếu liên tục đổi sang email mới, mỗi email có bộ đếm riêng và có thể chưa đạt ngưỡng 3. Điều này không phải do một lần đăng nhập đúng ở email khác đã “reset toàn bộ” hệ thống.

Sau khi CAPTCHA bắt buộc, gửi API trực tiếp mà không có captchaId hoặc captchaAnswer hợp lệ vẫn bị từ chối. Khi thử giải CAPTCHA, phải sử dụng mã hiện tại; đổi mã hoặc một lần thử thất bại có thể làm mã cũ không còn hợp lệ. Tải lại trang không xóa trạng thái lưu trong database.

11 Giới hạn IP thể hiện trên giao diện



Hình 12 Giao diện hiển thị Too many attempts khi hết hạn mức

Hình 12 cho thấy form đăng nhập hiển thị "Too many attempts. Try again later.". Khi đối chiếu với response 429 và cấu hình limiter, thông báo này tương ứng với việc số yêu cầu theo IP đã vượt ngưỡng. Chỉ nhìn giao diện không xác định được số lượt đã gửi; header của response cung cấp bằng chứng trực tiếp hơn.

Hai trạng thái cần phân biệt khi trình bày

Tình huống	Điều đang bị chặn	Cách xác nhận
CAPTCHA_REQUIRED	Một email đã đạt ngưỡng sai, cần CAPTCHA hợp lệ	401 cùng error.code và dữ liệu captcha
RATE_LIMIT	Nguồn IP đã dùng hết hạn mức request	429 cùng Retry-After và RateLimit
LOGIN_FAILED	Thông tin đăng nhập không hợp lệ	401; lần sai thứ 3 có thể kèm CAPTCHA
Đăng nhập thành công	Cặp hợp lệ đáp ứng các điều kiện hiện tại	200 cùng accessToken và user

Khi gặp 429, dừng lượt chạy và chờ theo Retry-After của response mới nhất. Giảm concurrency giúp giữ thứ tự nhưng không tự tạo thêm hạn mức. Không nên thay đổi hoặc tắt cơ chế bảo vệ chỉ để biến một kết quả bị chặn thành kết quả thành công trong báo cáo.

12 Kết quả kiểm thử đối chứng

Ngoài ảnh Burp, có log thử nghiệm HTTP trực tiếp tới cùng endpoint trong results.json, ghi thời điểm 01/10/2026 lúc 18:58:32 theo UTC+7. Đây là bằng chứng từ một lượt kiểm thử riêng, không phải ảnh chụp kết quả Intruder. Log ghi trạng thái, mã lỗi, có hay không CAPTCHA và token; không lưu giá trị token.

Sáu cặp đầu từ hai file

Dòng	Tài khoản	HTTP	CAPTCHA	Token
1	test	200	Không	Có
2	user001	401	Không	Không
3	user002	401	Không	Không
4	test	200	Không	Có
5	user003	401	Không	Không
6	user004	401	Không	Không

Các phản hồi 401 này không phân biệt email không tồn tại hay mật khẩu sai. Vì vậy, không kết luận các tài khoản user001–user004 chắc chắn tồn tại. Các phiên thành công tạo trong lần đối chứng đã được đăng xuất, với cleanupStatus bằng 200.

Chèn đăng nhập đúng giữa các lần sai của email A

Bước	Yêu cầu	HTTP	Kết quả
1	Email A với mật khẩu sai	401	LOGIN_FAILED, chưa CAPTCHA
2	Đăng nhập đúng tài khoản test	200	Cấp token
3	Email A với mật khẩu sai	401	LOGIN_FAILED, chưa CAPTCHA
4	Đăng nhập đúng tài khoản test	200	Cấp token
5	Email A với mật khẩu sai	401	LOGIN_FAILED, kèm CAPTCHA
6	Đăng nhập đúng tài khoản test	200	Cấp token
7	Email A không gửi CAPTCHA	401	CAPTCHA_REQUIRED, không token

Email A trong log là địa chỉ probe được tạo riêng cho lượt kiểm tra, không cần có tài khoản thật. Kết quả chứng minh việc chèn đăng nhập đúng ở email test không xóa trạng thái của A. Đây không phải bài thử vượt CAPTCHA bằng một tài khoản có mật khẩu đúng sau ngưỡng; trường hợp đó được kiểm tra riêng trong bộ test tích hợp của dự án.

13 Kịch bản demo có thể tái hiện

Demo một về việc gửi đúng request

Chờ cửa sổ rate limit còn đủ lượt. Nạp accounts-first6.txt và passwords-first6.txt, chọn Pitchfork, tắt encoding ở cả hai vị trí, bật cập nhật Content-Length, đặt concurrency bằng 1 và tắt baseline để đếm dễ hơn. Chạy một lần rồi đọc từng response. Nếu trạng thái môi trường không thay đổi, các dòng test trả 200, các cặp còn lại trong bộ đối chứng trả 401.

Demo hai về giả thuyết chèn tài khoản đúng

Dùng accounts-captcha.txt và passwords-captcha.txt đã chuẩn bị. Bộ này có 7 dòng: một email thử nghiệm A với mật khẩu sai được xen kẽ bằng tài khoản test hợp lệ. Bắt đầu khi A chưa có trạng thái CAPTCHA hoặc đã hết hạn; không chạy lại liên tục rồi so kết quả với trạng thái ban đầu.

Dừng ở từng mốc để giải thích: lần sai thứ nhất và thứ hai của A chưa có CAPTCHA; lần sai thứ ba kèm ảnh; sau một lần test đăng nhập đúng nữa, A vẫn nhận CAPTCHA_REQUIRED. Có thể chụp tab Raw hoặc Pretty của response ở bước 5 và 7 để thêm bằng chứng vào bài thuyết trình. Không cần chạy 300 request để chứng minh thuộc tính này.

Demo ba về bảo vệ theo IP

Các ảnh 429 đã có đủ bằng chứng về ngưỡng IP. Khi tái hiện, ghi lại số lượt còn lại trước lượt chạy và giữ lịch sử đầy đủ. Đến phản hồi 429 đầu tiên thì dừng, chụp status, RateLimit, Retry-After và tài khoản trong request. Không diễn giải chỉ số dòng Intruder như tổng số request server đã xử lý.

Lời giải thích khi thuyết trình

“Tôi dùng Pitchfork để gửi các cặp thông tin theo dòng. Tài khoản test hợp lệ giúp kiểm tra request được gửi đúng. Kết quả 200 không đồng nghĩa với vượt CAPTCHA. CAPTCHA đếm sai theo email, còn rate limit đếm yêu cầu theo IP. Khi chèn test giữa các lần sai của cùng một email khác, CAPTCHA vẫn kích hoạt. Khi dùng hết hạn mức IP, ngay cả test đúng cũng nhận 429.”

Tiêu chí để kết luận một bypass

Muốn kết luận vượt CAPTCHA, cần chứng minh cùng email đã ở trạng thái bắt buộc CAPTCHA nhưng vẫn nhận phiên hợp lệ khi thiếu hoặc sai CAPTCHA. Muốn kết luận vượt rate limit, cần chứng minh cùng khóa IP trong cùng cửa sổ đã cạn hạn mức nhưng vẫn được xử lý đăng nhập thành công. Bằng chứng hiện tại chưa thỏa hai tiêu chí này.

14 Đánh giá và khuyến nghị

Nhận định	Đánh giá theo bằng chứng
Intruder gửi được request đăng nhập	Đã ghi nhận 200 và 401 sau khi sửa định dạng payload.
Cặp admin trong lab được chấp nhận	Ảnh Hình 9 có accessToken và role ADMIN.
Chèn test vượt CAPTCHA của email khác	Không được hỗ trợ bởi bằng chứng; đối chứng ghi nhận CAPTCHA vẫn bắt buộc.
Đã vượt giới hạn IP	Chưa chứng minh; ảnh 429 cho thấy giới hạn hoạt động trong lượt tương ứng.
Bảo vệ chống mọi dạng brute force	Chưa thể kết luận; phạm vi mới là các kịch bản local đã mô tả.

Rủi ro rõ nhất của môi trường demo là tài khoản quản trị dùng thông tin đã biết và có trong tập thử. Nếu giữ thông tin mặc định khi triển khai thật, kẻ biết cặp đúng có thể đăng nhập trước khi CAPTCHA hoặc rate limit có lý do kích hoạt. Hai lớp bảo vệ này không thay thế việc quản lý mật khẩu và bảo vệ tài khoản quản trị.

Khi triển khai ngoài lab, loại bỏ tài khoản và mật khẩu demo, dùng mật khẩu riêng và MFA cho quản trị. Giữ bộ đếm CAPTCHA theo tài khoản và rate limit theo IP; cân nhắc thêm tín hiệu phát hiện thử nhiều tài khoản. Không đặt lại bộ đếm của các tài khoản khác khi một tài khoản đăng nhập thành công.

Nếu có nhiều backend hoặc reverse proxy, cần cấu hình nguồn IP đáng tin cậy và kho trạng thái rate limit dùng chung. Không tin tùy ý header do khách gửi. CAPTCHA ảnh nội bộ phù hợp minh họa offline; báo cáo này không đánh giá khả năng chống OCR hoặc mức độ tiếp cận cho người dùng có hạn chế thị lực.

Nguồn kiểm chứng

Tài liệu đầu vào: bruteforce.docx với 10 ảnh. Ảnh bổ sung: cấu hình payload encoding và kết quả dòng 28 trả 429 trong hội thoại. Log: pentest/runs/captcha-demo-20261001/results.json. Mã nguồn: backend/src/modules/auth/auth.routes.js và login-captcha.js; kiểm thử: backend/tests/integration/login-captcha.test.js.

[R1] PortSwigger — Intruder attack types. https://portswigger.net/burp/documentation/desktop/tools/intruder/configure-attack/attack-types

[R2] PortSwigger — Payload processing and encoding. https://portswigger.net/burp/documentation/desktop/tools/intruder/configure-attack/processing

[R3] PortSwigger — Attack settings. https://portswigger.net/burp/documentation/desktop/tools/intruder/configure-attack/settings

[R4] PortSwigger — Resource pools. https://portswigger.net/burp/documentation/desktop/tools/intruder/configure-attack/resource-pool